

Week 4

System and Endpoint Protection



Tauseef Ahmed, PhD
tahmed4@uel.ac.uk

Learning Objectives

By the end of this lecture, students will be able to:

- Explain methods for protecting systems and devices.
- Understand the endpoint security appliances
- Recommend endpoint and host-based security controls.
- Describe key Windows security features.
- Explain and apply the defence-in-depth approach.

1. Defending Systems and Devices

System Security – Planning

- The purpose of the system, the type of information stored, the applications and services provided, and their security requirements
- The categories of users of the system, the privileges they have, and the types of information they can access
- How the users are authenticated
- How access to the information stored on the system is managed
- What access the system has to information stored on other hosts, such as file or database servers, and how this is managed
- Who will administer the system and how they will manage the system (via local or remote access)
- Any additional security measures required on the system, including the use of host firewalls, anti-virus or other malware protection mechanisms, and logging

Operating Systems Security (Hardening)

- First critical step in securing a system is to secure the base operating system
- Basic steps
  - Install and patch the operating system
  - Harden and configure the operating system to adequately address the identified security needs of the system by:
    - Removing unnecessary services, applications, and protocols
    - Configuring users, groups, and permissions
    - Configuring resource controls
  - Install and configure additional security controls, such as antivirus, host-based firewalls, and intrusion detection system (IDS)
  - Test the security of the basic operating system to ensure that the steps taken adequately address its security needs

Initial Setup and Patching

- System security begins with the installation of the operating system
- Ideally, new systems should be constructed on a protected network
- Full installation and hardening process should occur before the system is deployed to its intended location
- Initial installation should install the minimum necessary for the desired system
- Overall boot process must also be secured
- The integrity and source of any additional device driver code must be carefully validated
- Patches are code updates that prevent a new virus, worm, or other malware from making a successful attack.
- Critical that a system be kept up to date, with all critical security related patches installed
- Should stage and validate all patches on test systems before deploying them in production

Remove Unnecessary Services, Applications, and Protocols

- If fewer software packages are available to run, the risk is reduced
- System planning process should identify what is actually required for a given system
- When performing the initial installation, the supplied defaults should not be used
  - Default configuration is set to maximize ease of use and functionality rather than security
  - If additional packages are needed later, they can be installed when they are required

Configure Users, Groups, and Authentication

- Not all users with access to a system will have the same access to all data and resources on that system
- Elevated privileges should be restricted to only those users who require them, and then only when they are needed to perform a task
- System planning process should consider:
  - Categories of users on the system
  - Privileges they have
  - Types of information they can access
  - How and where they are defined and authenticated
- Default accounts included as part of the system installation should be secured
  - Those which are not required should be either removed or disabled
  - Policies that apply to authentication credentials configured

Configure Resource Controls and Install Additional Security Controls

- Once the users and groups are defined, appropriate permissions can be set on data and resources
- Many of the security hardening guides provide lists of recommended changes to the default access configuration
- Further security possible by installing and configuring additional security tools:
  - Antivirus software
  - Host-based firewalls
  - IDS or IPS software
  - Allow-list applications

Test the System Security

- Final step in the process of initially securing the base operating system is security testing
- Goal:
  - Ensure the previous security configuration steps are correctly implemented
  - Identify any possible vulnerabilities
- Checklists are included in security hardening guides
- There are programs specifically designed to:
  - Review a system to ensure that it meets the basic security requirements
  - Scan for known vulnerabilities and poor configuration practices
- Should be done following the initial hardening of the system
- Repeated periodically as part of the security maintenance process

Application Configuration

- May include:
  - Creating and specifying appropriate data storage areas for application
  - Making appropriate changes to the application or service default configuration details
- Some applications or services may include:
  - Default data
  - Scripts
  - User accounts
- Of particular concern with remotely accessed services such as Web and file transfer services
  - Risk from this form of attack is reduced by ensuring that most of the files can be read, but not written, by the server

Encryption Technology

- Is a key enabling technology that may be used to secure data both in transit and when stored
- Must be configured and appropriate cryptographic keys created, signed, and secured
- If secure network services are provided using TLS or IPSec suitable public and private keys must be generated for each of them
- If secure network services are provided using SSH, an appropriate server and client keys must be created
- Cryptographic file systems are another use of encryption

Host Encryption

- The Windows Encrypting File System (EFS) feature allows users to encrypt files, folders, or an entire hard drive.

- Full disk encryption (FDE) encrypts the entire contents of a drive (including temporary files and memory).

- Microsoft Windows uses BitLocker for FDE.
  - To use BitLocker, the user needs to enable Trusted Platform Module (TPM) in the BIOS or UEFI.
  - TPM is a specialized chip on the motherboard that stores information about the host system, such as encryption keys, digital certificates, and passwords.

- Similarly, BitLocker To Go is a tool that encrypts removable drives. It does not use a TPM chip, but still encrypts the data, requiring a password to decrypt it.

Security Maintenance

- Process of maintaining security is continuous
- Security maintenance includes:
  - Monitoring and analyzing logging information
  - Performing regular backups
  - Recovering from security compromises
  - Regularly testing system security
  - Using appropriate software maintenance processes to patch and update all critical software and to monitor and revise configuration as needed

Boot Integrity

- Attackers can strike at any moment, even in the short space of time it takes for a system to start up. It is critical to ensure that systems and devices remain secure when booting up.
- Boot integrity ensures that the system can be trusted and has not been altered while the operating system loads.
- Firmware (software instructions about basic computer functions) is stored on a small memory chip on the motherboard. The BIOS is the first program that runs when you turn on the computer.
- Unified Extensible Firmware Interface (UEFI), a newer version of BIOS, defines a standard interface between the operating system, firmware, and external devices.
- Secure Boot is a security standard to ensure that a device boots using trusted software.
- Measured Boot provides stronger validation than Secure Boot.

Apple System Security Features

- Windows and Linux distributions include security features that are designed to protect endpoints.
- Apple provides system hardware and macOS security features that offer robust endpoint protection as well.
- Apple security features include the following:
  - **Security-focused hardware:** The hardware platform has enhanced security features such as a special CPU, boot, and a dedicated AES encryption engine.
  - **Encrypted storage:** Apple Data Protection and FileVault data storage encryption are supported by the hardware-based AES encryption engine.
  - **Secure boot:** The Boot ROM protects low-level hardware and only allows genuine and unaltered Apple OS software to run.

Apple System Security Features

- **Secure biometric data:** Processed in the security hardware system. This keeps it segregated from the OS and running application software, including malware.
- **Find My Mac:** Helps find lost or stolen macOS devices through its location tracking function. It also enables remote device locking and storage erasing if critical data is at risk.
- **XProtect:** Antimalware technology prevents the execution of malware through signature-based malware detection. It also alerts users to the existence of malware and provides the option to remove detected malware files.
- **Malware Removal Tool (MRT):** Detects and removes existing malware infections when detection rules are automatically updated by Apple. It also monitors for malware infections at system restart and user login.
- **Gatekeeper:** Ensures that only authentic, digitally-signed software that has been created by an Apple-notarized software developer is permitted to be installed.

Trusted Platform Module

- A concept being standardized by the **Trusted Computing Group**
- A hardware module that is used in hardware/software approach to trusted computing
- Trusted computing (TC) approach employs a TPM chip on a computer
- Generates keys that is shared with vulnerable components

TPM – Authentication Service

Authenticated Boot Service

- Boots the entire operating system in stages
- Assures that each portion of the O S is an approved version
- A tamper-evident log of the loading process is kept to detect tampering
- The tamper-resistant log contains a record that establishes which version of the OS is running.

TPM – Certification Service

Certification Service

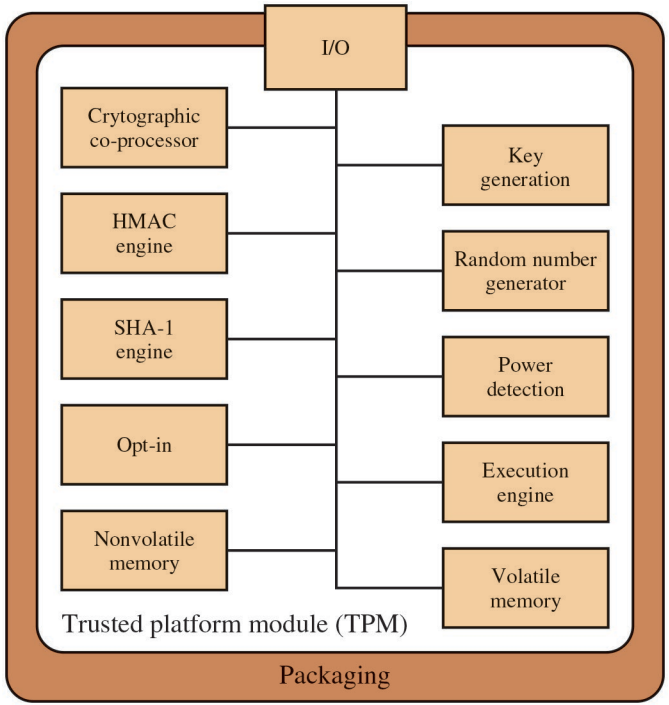
- The T P M produces a digital certificate by signing a formatted description of the configuration information using the T P M's private key.
- Another user can have confidence because
  - The T P M is considered trustworthy
  - Only the T P M possesses this T P M's private key

TPM – Encryption Service

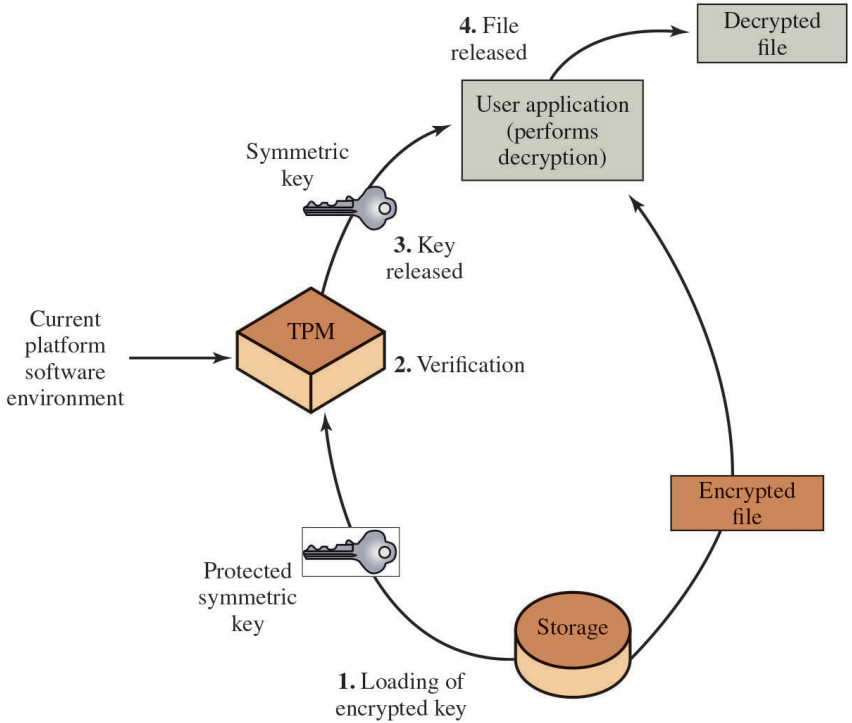
Encryption Service

- Enables data encryption in such a way that the data can be decrypted only by a certain machine
- T P M maintains a master secret key unique to this machine and generates a secret encryption key for every possible configuration of that machine
- This scheme can be extended upward

TPM Component Architecture



Decrypting a File Using a Protected Key



Physical Protection of Devices

Security measures that protect software and hardware threats:

- **Computer Equipment**
  - Use cable locks to secure devices
  - Keep telecommunication rooms locked
  - Use security cages (Faraday cages) around equipment to block electromagnetic fields.
- **Door locks**
  - A standard keyed entry lock is the most common type of door lock and are often easy to force open.
  - A deadbolt lock can be added for extra security.
  - A cipher lock uses buttons that are pressed in a given sequence to open the door.
- **Radio frequency identification (RFID) systems**
  - RFID uses radio waves to identify and track objects.
  - RFID tags are small, require little power, contain an integrated circuit connecting to an antenna, and can be attached to any item that an organization wants to track.

Host-Based Malware Protection

- People access corporate network resources with mobile devices that use remote access technologies such as VPN.
- These devices are also used on unsecured, or minimally secured, public and home networks.
- Host-based antimalware/antivirus software and host-based firewalls are used to protect these devices.
- Antivirus/Antimalware software is installed on a host to detect and mitigate viruses and malware.
- Antimalware programs may detect viruses using three different approaches:
  - **Signature-based** recognizes various characteristics of known malware files.
  - **Heuristics-based** recognizes general features shared by various types of malware.
  - **Behavior-based** employs analysis of suspicious behavior.

Other Host Based Security Solutions

- Host-based Firewall
  - A software installed on a host.
  - It restricts incoming and outgoing connections to connections initiated by that host only.
  - Some firewall software can also prevent a host from becoming infected and stop infected hosts from spreading malware to other hosts.
- Host-based Security Suites
  - It is recommended to install a host-based suite of security products on home networks as well as business networks.
  - They include antivirus, anti-phishing, safe browsing, Host-based intrusion prevention system, and firewall capabilities.
  - It provides a layered defense that will protect against most common threats.
- The independent testing laboratory AV-TEST provides high-quality reviews of host-based protections, as well as information about many other security products. (https://www.av-test.org/en/)

2. Host-Based Intrusion Detection and Prevention

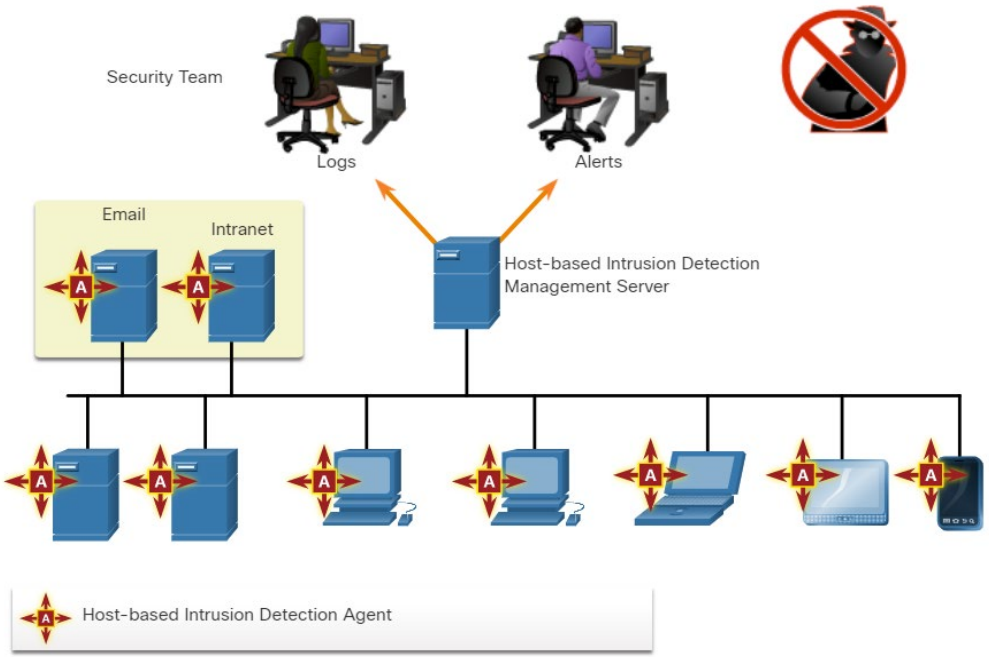
Host-Based Firewalls

- Host-based personal firewalls are standalone software programs that control traffic entering or leaving a computer.
- Host-based firewalls may use a set of predefined policies, or profiles, to control packets entering and leaving a computer.
- Host-based firewall applications can also be configured to issue alerts to users if suspicious behavior is detected.
- Distributed firewalls combine features of host-based firewalls with centralized management.

Host-Based Firewalls Examples

- Whether installed completely on the host or distributed, host-based firewalls are an important layer of network security along with network-based firewalls.
- Some examples of host-based firewalls:
  - **Windows Defender Firewall** uses a profile-based approach to firewall functionality.
  - **iptables** is an application that allows Linux system administrators to configure network access rules that are part of the Linux kernel Netfilter modules.
  - **nftables** is a Linux firewall application that uses a simple virtual machine in the Linux kernel.
  - **ufw** (Uncomplicated Firewall) is a user-friendly command-line program used to manage a Linux packet-filtering firewall built on top of netfilter, iptables, or nftables.
  - **TCP Wrappers** is a rule-based access control and logging system for Linux.

Host-Based Intrusion Detection (HIDS)



- A host-based intrusion detection system (HIDS) is designed to protect hosts against known and unknown malware.
- It adds a specialized layer of security software to vulnerable or sensitive systems
- can perform detailed monitoring and reporting on the system configuration and application activity.
- Monitors activity to detect suspicious behaviour, detect intrusions, log suspicious events, and send alerts
- It an detect both external and internal intrusions
- It is a comprehensive security application that combines the functionalities of antimalware applications with firewall functionality.

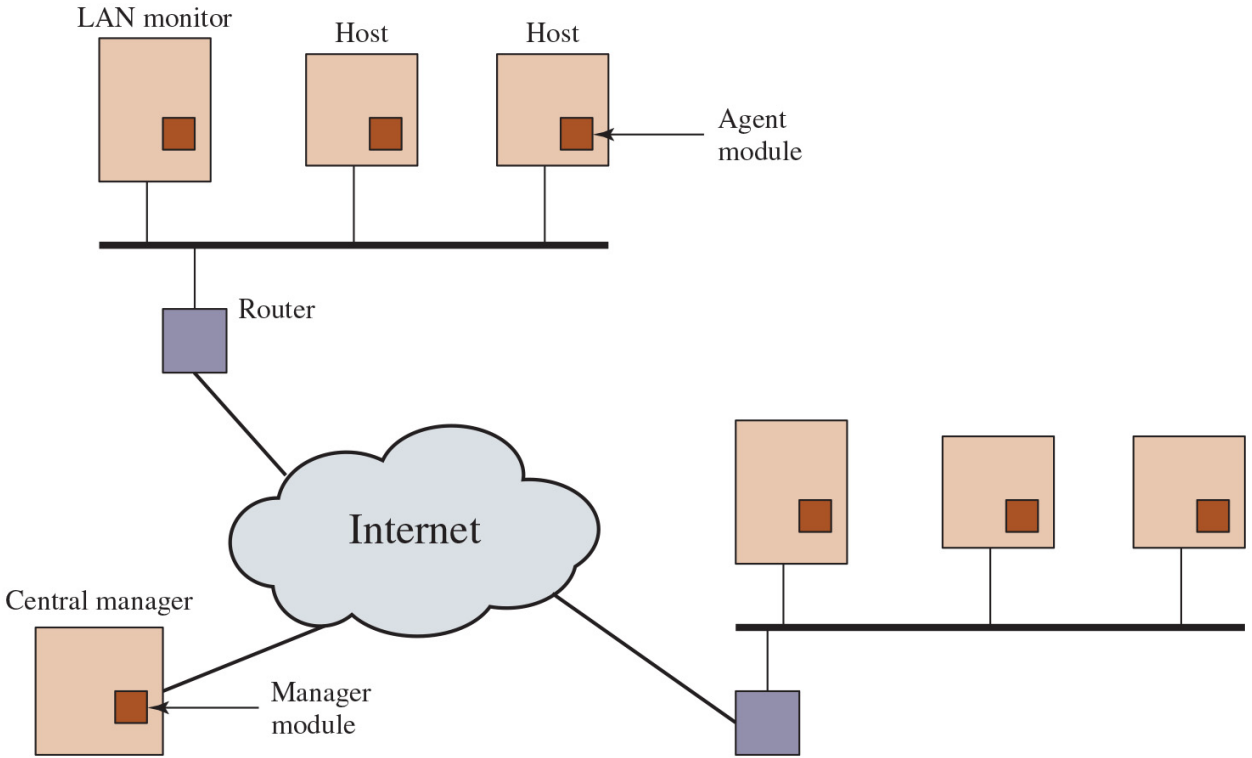
HIDS Operation

- HIDS uses both proactive and reactive strategies.
- HIDS uses signatures to detect known malware and prevent it from infecting a system (heuristic based).
- An additional set of strategies are used to detect the possibility of successful intrusions by malware that evades signature detection:
  - **Anomaly-based** - If an intrusion is detected, the HIDS can log details of the intrusion, send alerts to security management systems, and take action to prevent the attack.
  - **Policy-based** - HIDS may attempt to shut down software processes that have violated the rules and can log these events and alert personnel to violations. With some systems, administrators can create custom policies that can be distributed to hosts from a central policy management system.

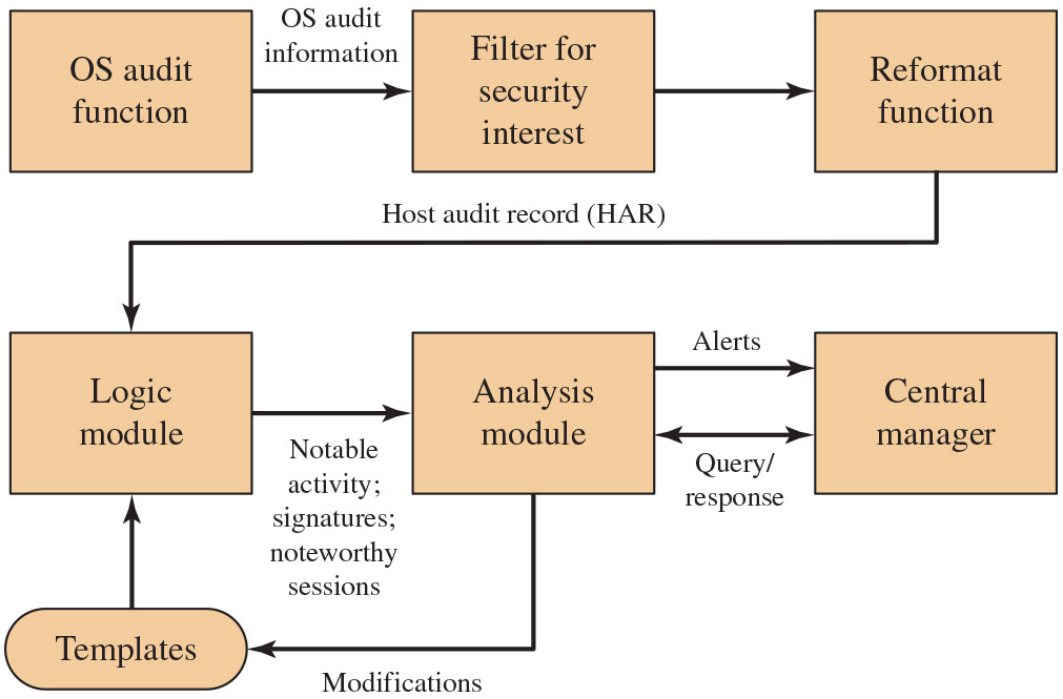
Data Sources and Sensors

- A fundamental component of intrusion detection is the sensor that collects data
- Common data sources include:
  - System call traces
  - Audit (log file) records
  - File integrity checksums
  - Registry access

Distributed Intrusion Detection



Agent Architecture



Host-Based Intrusion Prevention System (HIPS)

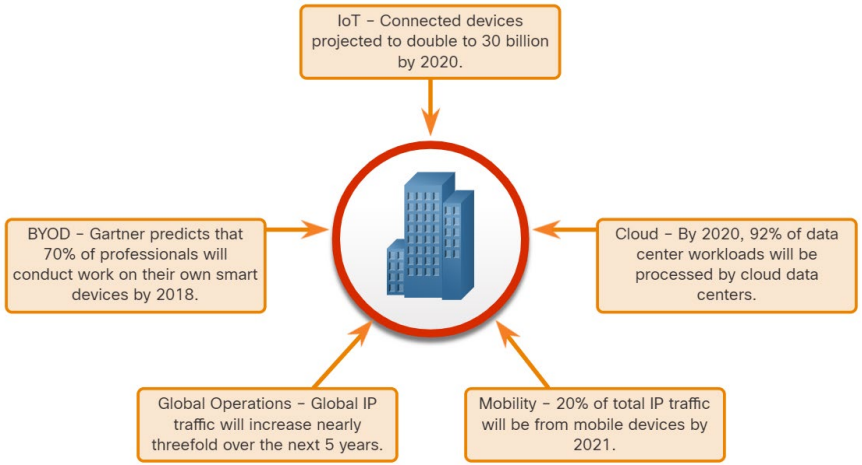
- Can make use of either signature/heuristic or anomaly detection techniques to identify attacks
  - Signature: focus is on the specific content of application network traffic, or of sequences of system calls, looking for patterns that have been identified as malicious
  - Anomaly: IPS is looking for behavior patterns that indicate malware
- Examples of the types of malicious behavior addressed by a HIPS include:
  - Modification of system resources
  - Privilege-escalation exploits
  - Buffer-overflow exploits
  - Access to e-mail contact list
  - Directory traversal

The Role of HIPS

- Many industry observers now see the enterprise endpoint, including desktop and laptop systems, as the main target for hackers and criminals
  - Thus, security vendors are focusing more on developing endpoint security products
  - Traditionally, endpoint security has been provided by a collection of distinct products, such as antivirus, antispyware, antispam, and personal firewalls
  - Approach is an effort to provide an integrated, single-product suite of functions
  - Advantages of the integrated HIPS approach are that the various tools work closely together, threat prevention is more comprehensive, and management is easier
  - A prudent approach is to use HIPS as one element in a defense-in-depth strategy that involves network-level devices, such as either firewalls or network-based IPS

3. Application Security

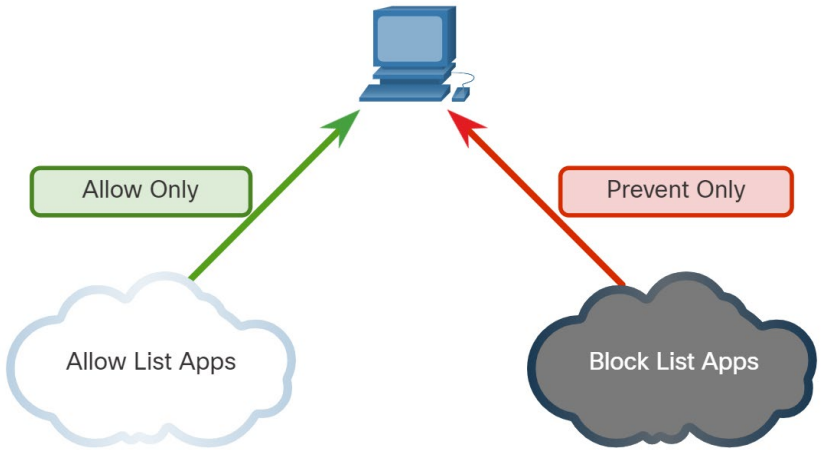
Attack Surface



- Attack surface: total sum of the vulnerabilities in each system that is accessible to an attacker and is continuing to expand.
- More devices are connecting networks through the Internet of Things (IoT) and Bring Your Own Device (BYOD).
- The SANS Institute describes three components of the attack surface:
  - **Network Attack Surface** - It exploits vulnerabilities in networks.
  - **Software Attack Surface** - It is delivered through exploitation of vulnerabilities in web, cloud, or host-based software applications.
  - **Human Attack Surface** - It exploits weaknesses in user behavior.

https://www.sans.org/webcasts/sans-2025-attack-surface-vulnerability-management-survey-hackers-dont-wait-why-should-we

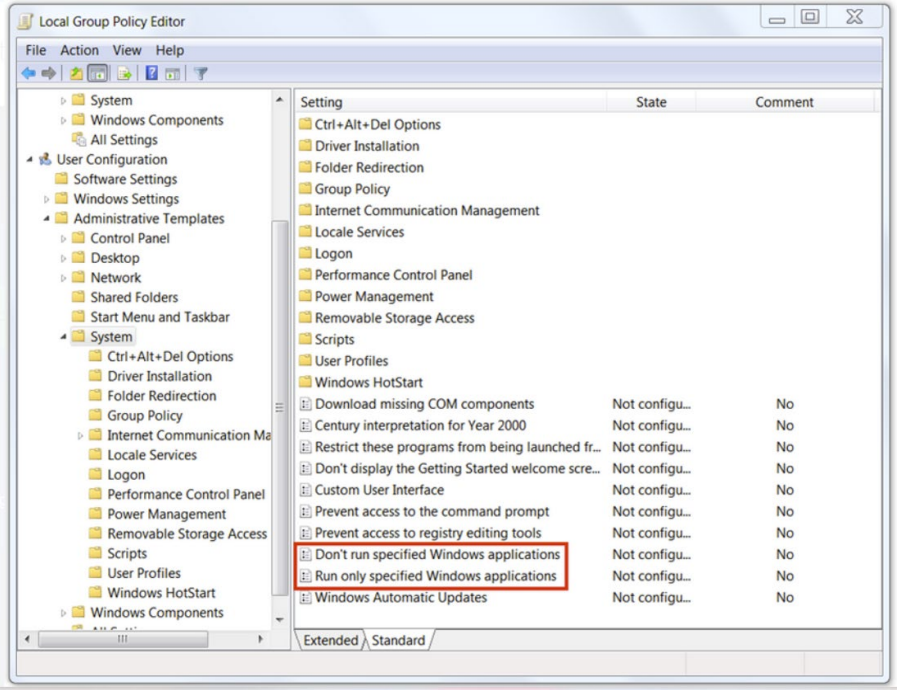
Application Block List and Allow List



- **Block lists** limit access to potential threats by creating lists of prohibited applications.
- Application block lists can dictate which user applications are not permitted to run on a computer.

- **Allow lists** can specify which programs are allowed to run, as shown in the figure.

Application Block List and Allow List



Windows Local Group Policy Editor block list and allow list settings

- Websites can also be allow-listed and block-listed.
- These block lists can be manually created, or they can be obtained from various security services.
- Block lists can be continuously updated by security services and distributed to firewalls and other security systems that use them.

System-Based Sandboxing

- Sandboxing is a technique that allows suspicious files to be executed and analyzed in a safe environment.
- Malware will enter the network despite the most robust perimeter and host-based security systems.
- HIDS and other detection systems can create alerts on suspected malware that may have entered the network and executed on a host.
- **Cuckoo Sandbox** is a popular free malware analysis system sandbox.

System-Based Sandboxing Example

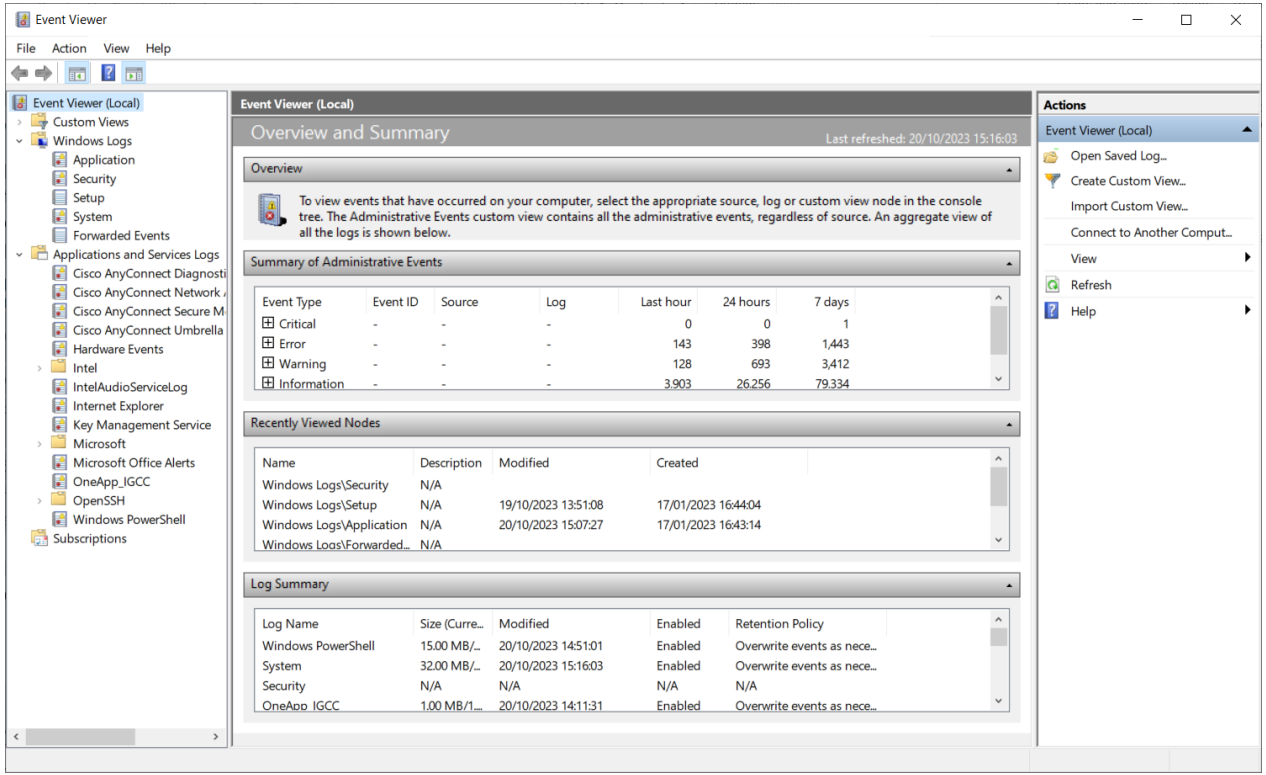


https://any.run/

- ANY.RUN, shown in the figure, offers the ability to upload a malware sample for analysis like any online sandbox.
- Offers a very rich interactive reporting functionality that is full of details regarding the malware sample.
- ANY.RUN runs the malware and captures a series of screen shots of the malware if it has interactive elements that display on the sandbox computer screen.

4. Windows Security

Windows Event Viewer



Windows Event Viewer

- Logs the history of application, security, and system events.
- These log files are a valuable troubleshooting tool because they provide information necessary to identify a problem.
- To open the Event Viewer, search for it and click the program icon, as shown in the figure.

Windows Logs

- Windows includes two categories of event logs:
  - Windows Logs
  - Application and Services Logs
- Events that are displayed in these logs have data of:
  - Log level: information, warning, error, or critical
  - Timestamp: date and time that the event occurred
  - Source and ID: source of the event and an ID which relates to that type of event
- Security event logs are found under Windows Logs.
- They use event IDs to identify the type of event.

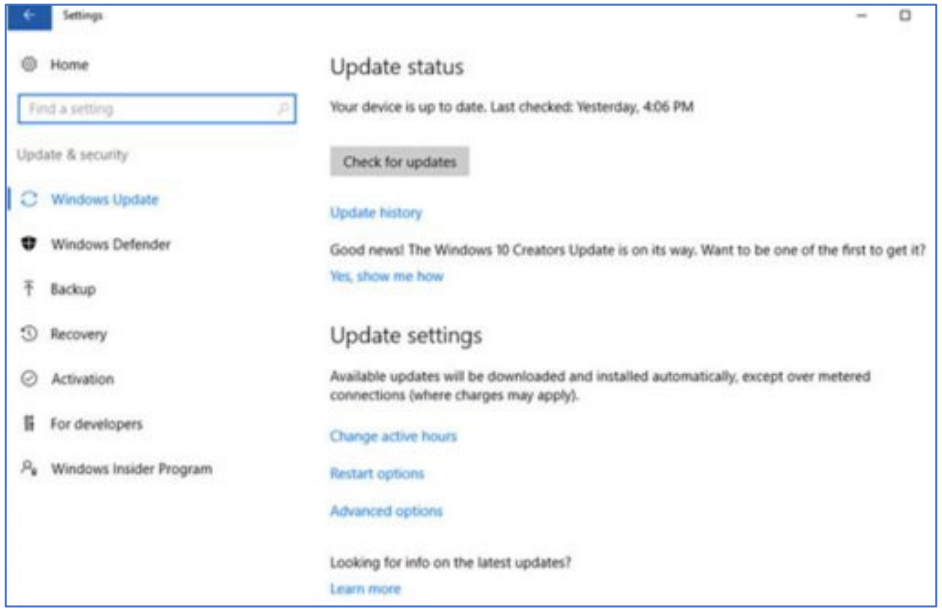
Windows Update Management

- Attackers are constantly producing new ways to compromise computers and exploit bad code.

- Microsoft is always trying to stay ahead of the attackers, so always make sure Windows is up to date with the latest service packs and security patches.

- Patches are code updates that manufacturers provide to prevent a newly discovered virus or worm from making a successful attack.

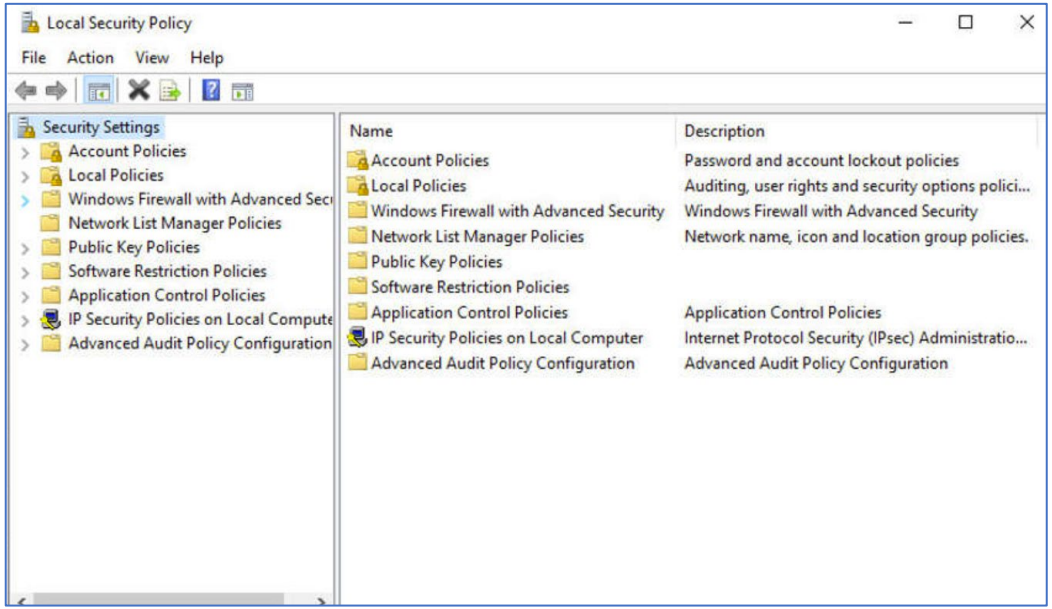
Windows Update Management (Cont.)



- Windows routinely checks the Windows Update website for high-priority updates that can help protect a computer from the latest security threats.
  - These updates include security updates, critical updates, and service packs.
  - Update status, shown in the figure, allows you to check for updates manually and see the update history of the computer.

Local Security Policy

- A security policy is a set of objectives that ensures the security of a network, the data, and the computer systems in an organization.
- The security policy is a constantly evolving document based on changes in technology, business, and employee requirements.



Windows Local Security Policy

- Active Directory is configured with Domains on a Windows Server.
- The admin configures a Domain Security Policy that applies to all computers that join the domain.
- Account policies are automatically set when a user logs in to a computer that is a member of a domain.
- Windows Local Security Policy, **shown in the figure**, can be used for stand-alone computers that are not part of an Active Directory domain.

What can be on the Local Security Policy?

- Password guidelines are an important component of a security policy.
- Passwords help prevent theft of data and malicious acts.
- Use the Account Lockout Policy in Account Policies to prevent brute-force login attempts.
- A security policy should contain a rule about requiring a computer to lock when the screensaver starts.
- If the Local Security Policy on every stand-alone computer is the same, then use the Export Policy feature.
- The Local Security Policy applet contains many other security settings that apply specifically to the local computer.
    - You can configure User Rights, Firewall Rules, and even the ability to restrict the files that users or groups are allowed to run with the AppLocker.

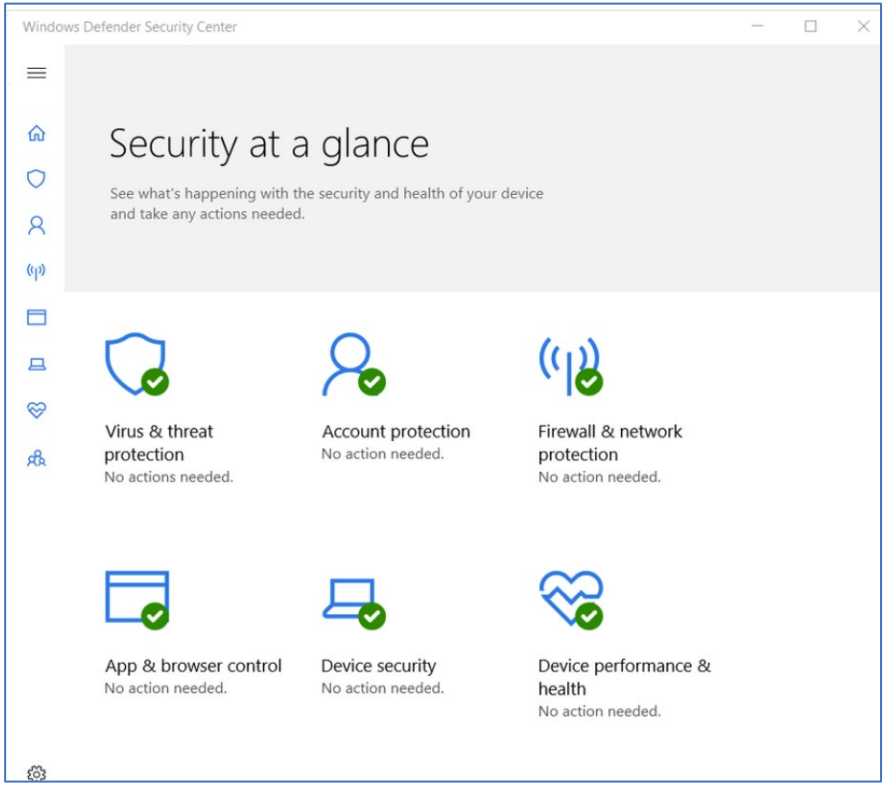
Windows Defender

Malware includes viruses, worms, Trojan horses, keyloggers, spyware, and adware. These are designed to invade privacy, steal information, damage the computer, or corrupt data. It is important that you protect computers and mobile devices using reputable antimalware software. The following types of antimalware programs are available:

Antimalware Programs	Description
Antivirus protection	This program continuously monitors for viruses. When a virus is detected, the user is warned, and the program attempts to quarantine or delete the virus.
Adware protection	This program continuously looks for programs that display advertising on your computer.
Phishing protection	This program blocks the IP addresses of known phishing websites and warns the user about suspicious sites.
Spyware protection	This program scans for keyloggers and other spyware.
Trusted/untrusted sources	This program warns you about unsafe programs about to be installed or unsafe websites before they are visited.

It may take several different programs and multiple scans to completely remove all malicious software. Run only one malware protection program at a time.

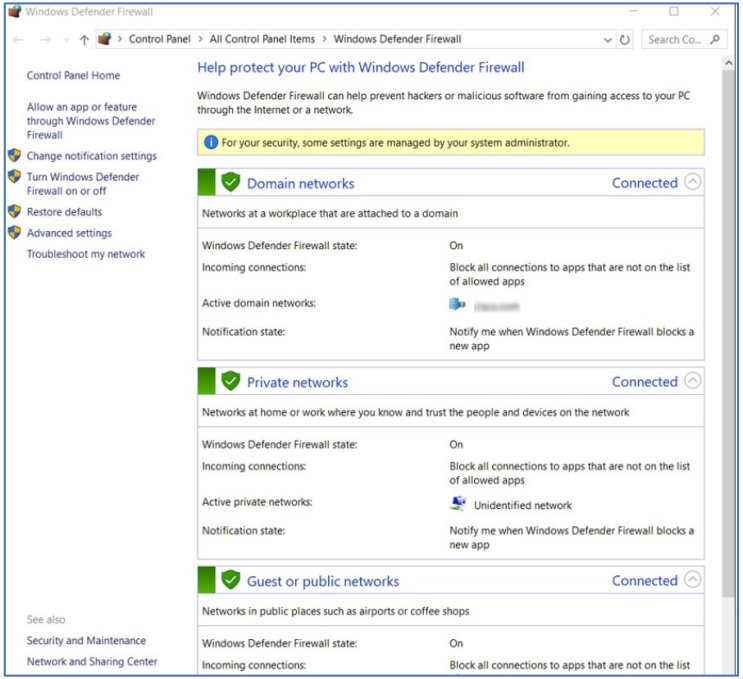
Windows Defender (Cont.)



- Several reputable security organizations such as McAfee, Symantec, and Kaspersky offer all-inclusive malware protection for computers and mobile devices.
- Windows has built-in virus and spyware protection called Windows Defender, as shown in the figure.
- Windows Defender is turned on by default to provide real-time protection against infection.

Windows Defender Firewall

- A firewall selectively denies traffic to a computer or network segment.
- Firewalls generally work by opening and closing the ports used by various applications.
  - By opening only, the required ports on a firewall, you are implementing a restrictive security policy.
  - Any packet not explicitly permitted is denied.
  - To allow program access through the Windows Defender Firewall, search for **Control Panels**. Under **Systems and Security**, locate **Windows Defender Firewall**. Click **Allow an app or feature through Windows Defender Firewall**, as shown in the figure.
  - To use a different software firewall, you will need to disable Windows Firewall. To disable the Windows Firewall, click **Turn Windows Firewall on or off**.
  - Many additional settings can be found under **Advanced settings**.



5. Defense-in-Depth

Assets, Vulnerabilities, Threats

- Cybersecurity analysts must prepare for any type of attack. It is their job to secure the assets of the organization's network.

- To do this, cybersecurity analysts must first identify:
  - **Assets** - Anything of value to an organization that must be protected including servers, infrastructure devices, end devices, and the greatest asset, data.

  - **Vulnerabilities** - A weakness in a system or its design that could be exploited by a threat actor.

  - **Threats** - Any potential danger to an asset.

Identify Assets

- The collection of all the devices and information owned or managed by an organization are assets.
- The assets constitute the attack surface that threat actors could target.
- As an organization grows, so do its assets. Consider the number of assets a large organization would have to protect.
- Asset management consists of inventorying all assets, and then developing and implementing policies and procedures to protect them.
- Organizations need to identify where critical information assets are stored, and how access is gained to that information.

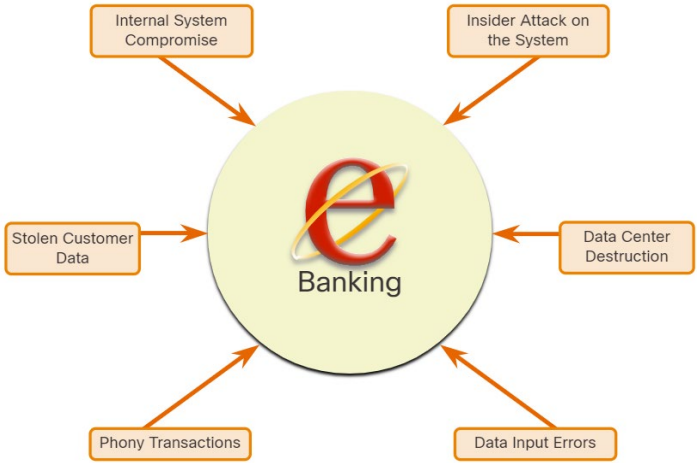
Asset Lifecycle Stages

- Part of the cybersecurity specialists' job is to manage information assets and related systems throughout that asset´s lifecycle. The stages of asset´s lifecycle are:

Procurement	The organization purchases the assets based on the needs identified from data gathered to justify the purchase. The asset is added to the organization's inventory.
Deployment	The asset is assembled and inspected to check for defects or other problems. Staff perform tests and install tags or barcodes for tracking purposes. The asset moves from inventory to in-use.
Utilization	This is the longest stage of the cycle. The asset's performance is continuously checked. Upgrades, patch fixes, new license purchases, and compliance audits are all part of the utilization stage.
Maintenance	It helps to extend an asset's productive life. Staff may modify or upgrade the asset.
Disposal	At the end of the asset's productive life, it must be disposed of. All data must be wiped from the asset. Disposal may include dismantling an asset for parts. Any parts that can cause an environmental hazard must be disposed of according to local guidelines.

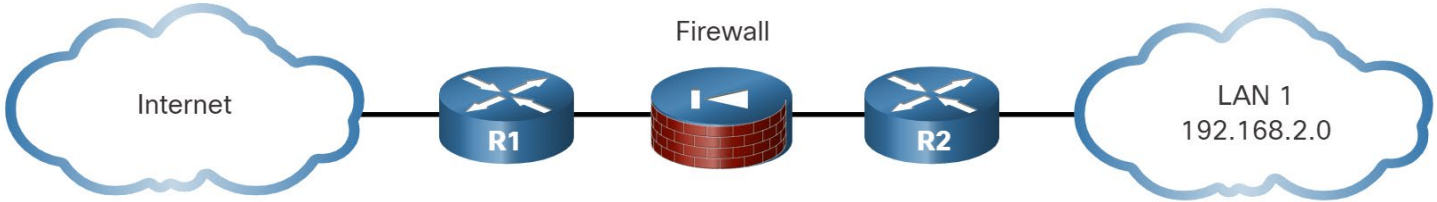
Identify Vulnerabilities

- Threat identification provides an organization with a list of likely threats for a particular environment.
- When identifying threats, it is important to ask several questions:
  - What are the possible vulnerabilities of a system?
  - Who may want to exploit those vulnerabilities to access specific information assets?
  - What are the consequences if system vulnerabilities are exploited, and assets are lost?



Defense-in-depth Approach

- Organizations must use a defense-in-depth approach to identify threats and secure vulnerable assets. It uses multiple layers of security at the network edge, within the network, and on network endpoints.



- Edge router (R1) - The first line of defense is the edge router, that has a set of rules specifying which traffic it allows or denies. It passes all connections that are intended for the internal LAN to the firewall.

- Firewall - The second line of defense is the firewall. It is a checkpoint device that performs additional filtering and tracks the state of the connections.

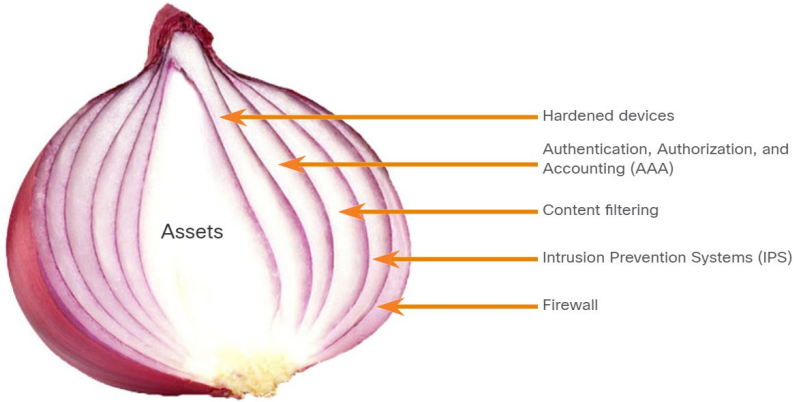
- Internal router (R2) - Another line of defense is the internal router. It can apply final filtering rules on the traffic before it is forwarded to its destination.

Defense-in-depth: Adding Layers

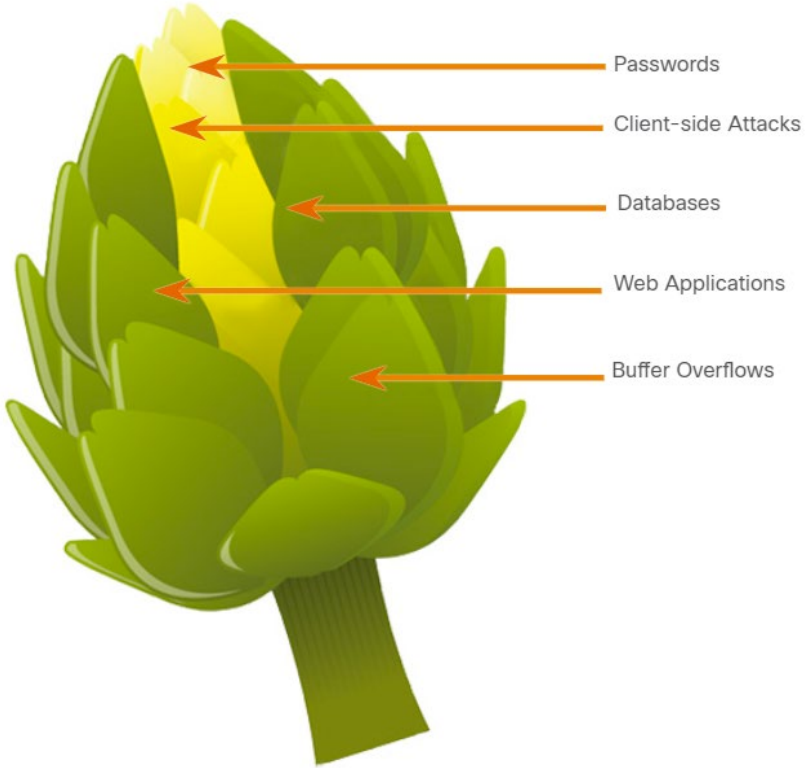
- Routers and firewalls are not the only devices that are used in a defense-in-depth approach.
- Other security devices include Intrusion Prevention Systems (IPS), Advanced Malware Protection (AMP), web and email content security systems, identity services, network access controls, and more.
- In the layered defense-in-depth security approach, the different layers work together to create a security architecture in which the failure of one safeguard does not affect the effectiveness of the other safeguards.

The Security Onion Model

- A common analogy used to describe a defense-in-depth approach.
- Core centric – focus is to secure core assets
- Multiple layers of security to reach the core assets.
- A traditional or classical model for enterprise where centralized resources are used within networks.
- A threat actor would have to peel away at a network's defenses layer by layer in a manner like peeling an onion.
- Only after penetrating each layer would the threat actor reach the target data or system.



The Security Artichoke Model



- Model suitable for decentralized network.
- The changing landscape of networking, such as the evolution of borderless networks, has changed this analogy to the “security artichoke”, which benefits the threat actor.
- Threat actors no longer peel away each layer.
- They only need to remove certain “artichoke leaves.”
- The bonus is that each “leaf” of the network may reveal sensitive data that is not well secured.
- The hacker chips away at the security armor along the perimeter to get to the “heart” of the enterprise.

Defense in Depth Strategies

- To make sure data and infrastructure remain secure, an organization should create different layers of protection:
  - **Layering:** To make sure data and information remains available, an organization must set up different layers of protection, creating a barrier of multiple defenses that work together to prevent attacks.
  - **Limiting:** Limiting access to data and information reduces the possibility of a security threat. An organization should restrict access so that each user only has the level of access required to do their job.
  - **Diversity:** If all defense layers were the same, it would not be very difficult for cybercriminals to succeed in an attack. The layers must be different so that if one layer is penetrated, the same technique will not work on all the others which would compromise the whole system.

Defense in Depth Strategies (Cont.)

- **Obscurity:** Obscuring information can also protect data and information. An organization should not reveal any information that cybercriminals can use to identify which Operating System (OS) a server is running, or the type or make of equipment or software it uses.

- **Simplicity:** Complexity does not necessarily guarantee security. If employees do not understand how to configure a solution properly, such as setting up their account using an unnecessarily complex process, this may make it just as easy for cybercriminals to compromise those systems.